

BANDUP

06 - OPERATIONS

Triển khai, vận hành, giám sát và xử lý sự cố

Phiên bản: 1.0

Trạng thái: Baseline

Phạm vi: Staging, Production và Early Operations

Hạ tầng ban đầu: VPS + Docker Compose

Đối tượng: Solo developer / nhóm vận hành nhỏ

Thông tin tài liệu

Thuộc tính	Nội dung
Tên tài liệu	06_Operations
Phiên bản	1.0
Mục đích	Quy định cách triển khai, vận hành, giám sát, sao lưu, khôi phục và xử lý sự cố cho BandUp sau khi hệ thống được đưa lên VPS.
Đối tượng sử dụng	Product Owner, developer, DevOps/operations, admin có quyền vận hành, người xử lý support và incident.
Tài liệu đầu vào	01_Product_Overview, 02_Product_Requirements, 03_UI_UX_Design, 04_System_Design và 05_Development_Roadmap.
Phạm vi triển khai	Development, Staging, Production; Web, API, Worker, Database, Hangfire, OpenAI, payOS và storage.
Ngoài phạm vi	Chi tiết code, test case cấp thấp, thiết kế UI và hợp đồng pháp lý chính thức.

Câu hỏi trung tâm: Sau khi BandUp được đưa lên VPS, làm thế nào để hệ thống chạy ổn định, bảo mật, không mất dữ liệu, không phát sinh chi phí AI bất thường và có thể khôi phục khi xảy ra sự cố?

Contents

Thông tin tài liệu	1
1 Mục đích và phạm vi	2
2 Mục tiêu vận hành	2
3 Nguyên tắc vận hành	3
3.1 Tự động hóa thao tác lặp lại	3
3.2 Không thử nghiệm trực tiếp trên Production	3
3.3 Backup chỉ có giá trị khi restore được	3
3.4 Truy vết là yêu cầu bắt buộc	3
3.5 Ưu tiên phục hồi luồng cốt lõi	3
4 Mô hình môi trường	3
4.1 Development	4
4.2 Staging	4
4.3 Production	4

5 Kiến trúc triển khai VPS	4
5.1 Topology ban đầu	5
5.2 Docker Compose services	5
5.3 Persistent volumes	5
6 Domain, DNS và HTTPS	5
7 Quản lý configuration và secret	6
7.1 Nhóm secret	6
7.2 Cách lưu	6
7.3 Business settings	6
7.4 Secret rotation	7
8 CI/CD	7
8.1 Pull Request pipeline	7
8.2 Staging deployment	7
8.3 Production deployment	7
9 Release management	8
10 Rollback	8
10.1 Application rollback	8
10.2 Database rollback	8
10.3 Điều kiện rollback	8
11 Database migration	9
12 Health checks	9
13 Logging	9
13.1 Structured fields	9
13.2 Dữ liệu không được log	9
13.3 Log level	9
14 Audit logging	10
15 Metrics và dashboards	10
15.1 API metrics	10
15.2 Database metrics	10
15.3 Hangfire metrics	10
15.4 OpenAI metrics	10
15.5 Payment/Credit metrics	11

15.6 Product metrics	11
15.7 Dashboard tối thiểu	11
16 Alerting	11
17 Vận hành Hangfire	12
17.1 Queues và concurrency	12
17.2 Dashboard	12
17.3 Recovery jobs	12
17.4 Retry	12
18 Vận hành OpenAI	13
18.1 Budget controls	13
18.2 Provider incident	13
18.3 Prompt deployment	13
18.4 AI quality monitoring	14
19 Vận hành BandUp Credit	14
19.1 Ledger là nguồn dữ liệu chính	14
19.2 Credit reconciliation	14
19.3 Admin adjustment	14
20 Vận hành payOS	14
20.1 Webhook processing	14
20.2 Payment reconciliation	15
20.3 Refund	15
21 Support operations	15
21.1 Priority	15
21.2 Workflow	15
22 Backup strategy	15
22.1 Database	15
22.2 Object storage	16
22.3 Configuration	16
23 Restore và disaster recovery	16
23.1 Restore test	16
23.2 Restore Production	16
23.3 RPO và RTO mục tiêu	16

24 Data retention	16
25 Xóa tài khoản	17
25.1 Workflow	17
25.2 Dữ liệu xóa	17
25.3 Dữ liệu giữ tối thiểu	17
25.4 Backup	17
26 Security operations	17
26.1 Access policy	18
26.2 Review định kỳ	18
26.3 Admin security	18
26.4 Patch management	18
27 Dependency và vulnerability management	18
28 Capacity và performance	18
29 Cost management	19
29.1 Nhóm chi phí	19
29.2 AI cost	19
29.3 Profitability	19
30 Maintenance Mode	19
31 Incident management	19
31.1 Severity	19
31.2 Quy trình	20
32 Runbook catalog	20
33 Runbook mẫu: OpenAI lỗi diện rộng	20
33.1 Triệu chứng	20
33.2 Xử lý	20
33.3 Xác minh	21
34 Runbook mẫu: Payment không cộng credit	21
34.1 Kiểm tra	21
34.2 Xử lý	21
35 Postmortem	21
36 Lịch bảo trì định kỳ	21

37 Production access policy	22
38 Go-Live Checklist	22
38.1 Infrastructure	22
38.2 Security	22
38.3 Data	22
38.4 Product và Operations	22
39 Operations Acceptance Criteria	23
40 Phụ lục A - Environment Variables Checklist	23
41 Phụ lục B - Service Dependency Matrix	24
42 Phụ lục C - Release Checklist	24
43 Phụ lục D - Monthly Maintenance Checklist	24
44 Kết luận	25

1. Mục đích và phạm vi

Tài liệu Operations chuyển thiết kế kỹ thuật thành quy trình vận hành có thể thực thi. Nội dung bao gồm:

- Mô hình môi trường Development, Staging và Production.
- Kiến trúc triển khai trên VPS, Docker Compose và reverse proxy.
- Quản lý domain, HTTPS, configuration và secret.
- CI/CD, release, migration, smoke test và rollback.
- Logging, monitoring, metrics và alerting.
- Vận hành Hangfire, OpenAI, BandUp Credit và payOS.
- Backup, restore, data retention và account deletion.
- Security operations, access control và patch management.
- Incident response, runbook và postmortem.
- Checklist go-live và lịch bảo trì định kỳ.

Tài liệu không thay thế System Design, Test Plan hoặc tài liệu pháp lý. Khi chính sách pháp luật, điều khoản của nhà cung cấp hoặc mô hình hạ tầng thay đổi, phần liên quan phải được rà soát và cập nhật.

2. Mục tiêu vận hành

ID	Mục tiêu
OPS-01	Triển khai và cập nhật ứng dụng mà không làm mất dữ liệu.
OPS-02	Có thể rollback application khi release mới gây lỗi.
OPS-03	User không mất bài viết đã autosave trong điều kiện vận hành bình thường.
OPS-04	Credit không bị cộng sai, trừ sai hoặc xử lý trùng.
OPS-05	Payment không được cộng credit hai lần khi webhook được gửi lặp.
OPS-06	AI lỗi không làm user mất credit.
OPS-07	Phát hiện sớm chi phí OpenAI tăng bất thường.
OPS-08	Phát hiện queue nghẽn, worker dừng hoặc job bị kẹt.
OPS-09	Có ít nhất một bản backup nằm ngoài VPS chính.
OPS-10	Quy trình restore phải được kiểm thử định kỳ.
OPS-11	Secret không nằm trong source code, frontend hoặc log.
OPS-12	Admin action nhạy cảm phải có audit.
OPS-13	Dữ liệu hết thời hạn được xóa tự động theo retention policy.
OPS-14	Có runbook cho các sự cố phổ biến và nghiêm trọng.
OPS-15	Hệ thống có thể được vận hành bởi một người trong giai đoạn đầu nhưng vẫn có khả năng truy vết.

3. Nguyên tắc vận hành

3.1 Tự động hóa thao tác lặp lại

Các công việc nên được tự động hóa tối đa:

- Build, lint và automated test.
- Build Docker image và deploy Staging.
- Database backup và kiểm tra trạng thái backup.
- Log cleanup, draft cleanup và attachment cleanup.
- Payment reconciliation và credit reconciliation.
- Tổng hợp usage/cost và kiểm tra budget.
- Health check và alerting.

3.2 Không thử nghiệm trực tiếp trên Production

Development → Pull Request → CI → Staging → Smoke Test → Phê duyệt → Production

Production không được dùng để thử migration, prompt mới, payment flow mới hoặc dependency mới chưa được kiểm tra trên Staging.

3.3 Backup chỉ có giá trị khi restore được

Một file backup tồn tại không đồng nghĩa hệ thống có thể phục hồi. Restore test phải kiểm tra ít nhất: user, submission, assessment, payment, credit ledger và migration state.

3.4 Truy vết là yêu cầu bắt buộc

Mỗi sự cố quan trọng phải xác định được các thông tin khi phù hợp:

- Trace ID, User ID, Submission ID, Payment Order ID và Job ID.
- Phiên bản application, environment và thời điểm.
- Admin đã thao tác, lý do và giá trị trước/sau.

3.5 Ưu tiên phục hồi luồng cốt lõi

Authentication → Writing Draft → Submission → AI Grading → Credit → Payment → Result
→ Progress/Analytics

Khi hạ tầng bị giới hạn, có thể tạm dừng analytics, email hoặc aggregation để giữ luồng viết, chấm, credit và payment an toàn.

4. Mô hình môi trường

Môi trường	Mục đích	Dữ liệu	Dịch vụ ngoài
Development	Phát triển local, debug, unit/integration test	Dữ liệu giả hoặc seed	OpenAI key dev giới hạn; fake payment; local storage
Staging	Kiểm thử gần Production và smoke test release	Dữ liệu test riêng	Google callback riêng; payOS test; OpenAI key riêng
Production	Phục vụ user thật và payment thật	Dữ liệu thật	Production credentials, domain chính và backup thật

4.1 Development

Môi trường local chạy bằng Docker Compose hoặc các process riêng:

- React Web, ASP.NET Core API và BandUp Worker.
- Cùng loại database với Production.
- Hangfire persistent storage.
- Local Object Storage và Development Email Sender.
- OpenAI key dev có budget thấp và dữ liệu test.

Không sử dụng payment production trong Development.

4.2 Staging

Staging phải gần Production ở các yếu tố ảnh hưởng hành vi:

- Docker image cùng build artifact với release candidate.
- Cùng loại database, reverse proxy, HTTPS và migration flow.
- Google OAuth client/callback riêng.
- payOS test/sandbox hoặc quy trình test được kiểm soát.
- Không sao chép essay hoặc thông tin cá nhân Production sang Staging nếu chưa anonymize.

4.3 Production

Production sử dụng credentials, domain, database, storage và support channel riêng. Không dùng user test hoặc seed payment giả trong Production.

5. Kiến trúc triển khai VPS

5.1 Topology ban đầu

Internet

→Caddy hoặc Nginx

→BandUp Web / BandUp API / Admin Portal

→PostgreSQL hoặc database đã chốt

→Hangfire persistent storage

BandUp Worker xử lý: grading, notification, payment reconciliation, cleanup và data deletion.

5.2 Docker Compose services

Service	Vai trò	Yêu cầu vận hành
reverse-proxy	HTTPS, routing, security header, access log	Chỉ mở port 80/443; cấu hình redirect HTTPS
bandup-web	Static web bundle	Stateless; có thể thay image không ảnh hưởng dữ liệu
bandup-api	HTTP API, auth, business logic	Health check; không chạy job dài trong request
bandup-worker	Hangfire Server và recurring jobs	Có restart policy; worker count cấu hình được
database	Dữ liệu nghiệp vụ và Hangfire storage	Persistent volume, backup, không public Internet

Các service có thể bổ sung khi cần: Redis, monitoring agent, log collector và external object storage gateway.

5.3 Persistent volumes

Cần persist:

- Database data.
- ASP.NET Data Protection key ring.
- File storage nếu dùng VPS volume.
- Reverse proxy certificate/configuration khi cần.
- Backup staging area tạm thời.

Không lưu dữ liệu dài hạn trong filesystem nội bộ của container nếu không mount volume. Container có thể bị xóa và tạo lại trong quá trình deploy.

6. Domain, DNS và HTTPS

Đề xuất same-origin:

```
https://bandup.vn  
https://bandup.vn/api/...  
https://bandup.vn/admin
```

Lợi ích: cookie dễ cấu hình, giảm CORS, Google Login đơn giản hơn và CSRF rõ ràng hơn.

Reverse proxy chịu trách nhiệm:

- HTTPS termination và redirect HTTP sang HTTPS.
- Routing đến Web/API.
- Request size limit và timeout hợp lý.
- Security headers và compression phù hợp.
- Access log đã hạn chế dữ liệu nhạy cảm.

Production bắt buộc HTTPS. Database, Hangfire Dashboard và internal metrics không được public trực tiếp.

7. Quản lý configuration và secret

7.1 Nhóm secret

- Database connection string.
- Google Client Secret.
- OpenAI API key.
- payOS credentials và webhook checksum/signature key.
- Email và object storage credentials.
- Encryption key hoặc signing key nội bộ nếu có.

Secret không được commit, gửi xuống frontend, hiển thị trong Admin Portal hoặc ghi vào log.

7.2 Cách lưu

Giai đoạn VPS có thể dùng:

- Environment variables.
- Docker secrets nếu phù hợp.
- File .env chỉ tồn tại trên server, không commit và được giới hạn permission.
- Secret manager khi chuyển sang cloud/managed infrastructure.

7.3 Business settings

Các setting có thể lưu trong database và quản lý theo permission:

- MaxEssayWords, MinEssayWords.
- CreditCostPerGrading.

- AiGradingEnabled, FreeGradingEnabled.
- DailyAiBudgetLimit, MaxConcurrentAiJobs.
- MaintenanceMode.

Secret và business setting phải được tách biệt.

7.4 Secret rotation

Phải có runbook thay OpenAI key, Google secret, payOS credential và database password. Việc thay secret không được yêu cầu chỉnh source code; có thể cần restart service có kiểm soát.

8. CI/CD

8.1 Pull Request pipeline

Restore Dependencies → Build Backend → Build Frontend → Lint → Unit Test → Integration Test → Migration Check → Docker Build

Không merge khi pipeline thất bại.

8.2 Staging deployment

1. Build image có version và push vào registry.
2. Backup Staging nếu migration có rủi ro.
3. Apply migration.
4. Deploy Web/API/Worker.
5. Chạy readiness check và smoke test.
6. Ghi lại release candidate và kết quả test.

8.3 Production deployment

1. Tạo release tag và release notes.
2. Build artifact/image cố định.
3. Backup Production database.
4. Apply migration tương thích ngược.
5. Deploy services theo thứ tự an toàn.
6. Chạy readiness và smoke test.
7. Theo dõi error rate, queue, payment và AI metrics sau release.

Không dùng tag latest làm nguồn duy nhất. Dùng version cụ thể như bandup-api : 1.0.3.

9. Release management

Mỗi release phải ghi:

- Version, ngày phát hành và người triển khai.
- Thay đổi chức năng và bug fix.
- Migration/configuration mới.
- Risk và rollback procedure.
- Kết quả smoke test và trạng thái theo dõi sau deploy.

Có thể sử dụng Semantic Versioning: MAJOR . MINOR . PATCH.

Loại release	Ví dụ	Yêu cầu
Patch	Fix UI, validation, lỗi nhỏ	CI, Staging smoke test, rollback image
Minor	Tính năng mới tương thích	Integration/E2E test, migration review
Major/Risk cao	Auth, payment, credit, grading schema, retention	Kế hoạch rollout, backup, rollback và theo dõi tăng cường

10. Rollback

10.1 Application rollback

Deploy lại image version trước nếu application release gây lỗi nhưng schema vẫn tương thích.

10.2 Database rollback

Ưu tiên Expand-and-Contract:

Thêm cột/bảng mới → Deploy code hỗ trợ cũ và mới → Chuyển dữ liệu → Xác minh → Xóa cấu trúc cũ ở release sau

Không xóa cột cũ ngay trong cùng release nếu code cũ cần cột đó để rollback.

10.3 Điều kiện rollback

Rollback khi có một trong các tình huống:

- Login lỗi diện rộng.
- User không truy cập được draft hoặc submission.
- Payment/credit bị xử lý sai.
- Error rate tăng mạnh hoặc database lock nghiêm trọng.
- AI call tăng bất thường do lỗi release.
- Migration làm hỏng hoặc mất dữ liệu.

11. Database migration

- Migration nằm trong source control.
- Không chỉnh schema Production thủ công nếu không có change record.
- Backup trước migration quan trọng.
- Chạy thử migration trên Staging với dữ liệu đủ lớn.
- Đánh giá lock, duration và khả năng tương thích ngược.
- Không seed user/payment/submission giả vào Production.

Có thể seed Roles, Permissions, Error Taxonomies, App Settings và Credit Packages mặc định. Migration log nên có version, release, thời điểm, trạng thái và người triển khai.

12. Health checks

Endpoint	Mục đích	Kiểm tra
/health/live	Process còn sống	Không cần gọi database hoặc dịch vụ ngoài
/health/ready	Có thể nhận traffic	Database, Hangfire storage, configuration bắt buộc, storage nếu là dependency cứng

Không gọi OpenAI hoặc payOS trong mọi health check vì làm tăng phụ thuộc, quota và cảnh báo giả. Thay vào đó, theo dõi chúng bằng metrics/probe riêng có tần suất thấp.

13. Logging

13.1 Structured fields

Log nên chứa khi phù hợp:

Timestamp - Level - TraceId - UserId - SubmissionId - PaymentOrderId - JobId - Module - EventName - ElapsedMs - ApplicationVersion - Environment

13.2 Dữ liệu không được log

- Cookie, Google token, API key và password.
- payOS secret hoặc database credential.
- Toàn bộ essay và raw AI prompt/response theo mặc định.
- Dữ liệu cá nhân không cần thiết cho chẩn đoán.

13.3 Log level

Level	Cách dùng
Information	Hoạt động bình thường quan trọng: submission accepted, job completed, payment confirmed
Warning	Bất thường có thể tự phục hồi: retry, queue chậm, webhook đến trễ
Error	Request/job thất bại cần điều tra
Critical	Nguy cơ mất dịch vụ, dữ liệu, tiền hoặc secret

14. Audit logging

Audit dùng để trả lời ai đã làm gì, với tài nguyên nào và vì sao. Các hành động bắt buộc audit:

- Thay đổi role/permission, suspend user và revoke session.
- Điều chỉnh/refund credit và xử lý payment/refund.
- Publish/unpublish prompt và chỉnh taxonomy.
- Thay đổi App Settings, budget, maintenance hoặc kill switch.
- Truy cập nội dung essay của user cho mục đích hỗ trợ.

Audit record đề xuất:

ActorUserId - Action - ResourceType - ResourceId - Reason - OldValue - NewValue - IpAddress - UserAgent - CreatedAt

Admin thông thường không được sửa hoặc xóa audit log.

15. Metrics và dashboards

15.1 API metrics

Request count, latency, error rate, status distribution và active requests.

15.2 Database metrics

Connection count, slow query, lock, database size, disk usage và backup status.

15.3 Hangfire metrics

Enqueued, Processing, Scheduled, Failed, Retry count, queue waiting time, processing duration và worker count.

15.4 OpenAI metrics

Calls, success/failure, input/output token, cost, latency, retry, structured-output validation failure và cost per essay.

15.5 Payment/Credit metrics

Payment created/paid/failed/expired, webhook error, reconciliation failure, credit grant failure, refund, reservation quá hạn và ledger mismatch.

15.6 Product metrics

New user, active user, submission, completed grading, result viewed, payment conversion, support ticket và account deletion.

15.7 Dashboard tối thiểu

Dashboard	Nội dung
System	Availability, error rate, CPU, RAM, disk, database và queue
AI	Calls, token, cost, latency, retry, budget và failure reason
Payment	Success, pending, webhook error, credit grant và refund
Product	User, submission, retention, conversion và cost per active user

Dashboard phải giúp trả lời: hệ thống đang có vấn đề ở đâu và có cần hành động ngay không?

16. Alerting

Cảnh báo	Mức độ	Hành động ban đầu
API hoặc database không hoạt động	Critical	Maintenance/containment, kiểm tra hạ tầng
Payment paid nhưng credit không cộng	Critical	Tạm dừng payment grant nếu diện rộng, reconciliation
Credit ledger mất cân bằng	Critical	Khóa adjustment tự động, điều tra transaction
Disk gần đầy	High/Critical	Cleanup log, mở rộng disk, bảo vệ database
AI cost vượt budget	High	Giảm concurrency, tắt free grading hoặc kill switch
AI failure rate tăng mạnh	High	Circuit breaker, kiểm tra provider/key
Queue waiting quá lâu	High	Kiểm tra worker, provider và database
Backup thất bại	High	Chạy lại, xác minh offsite target

Webhook payOS lỗi liên tục	High	Kiểm tra signature/config, reconciliation
Support ticket tồn lâu	Warning	Phân công và xử lý backlog

Kênh cảnh báo ban đầu: email và in-app admin notification; có thể bổ sung Telegram/Slack-/Discord.

17. Vận hành Hangfire

17.1 Queues và concurrency

Queue	Concurrency ban đầu	Loại job
grading	2-3	OpenAI grading và corrective retry
notifications	1-2	In-app notification và email
payments	1	Reconciliation và payment recovery
maintenance	1	Cleanup, aggregation và data deletion

Concurrency là configuration, không hard-code. Tăng worker phải dựa trên OpenAI rate limit, cost, database load và queue latency.

17.2 Dashboard

Hangfire Dashboard phải:

- Không public; chỉ Operations/Super Admin.
- Có thể giới hạn IP.
- Không chứa essay hoặc secret trong job arguments.
- Job chỉ nhận Resource ID như SubmissionId.

17.3 Recovery jobs

Recurring job kiểm tra:

- Submission QUEUED quá lâu nhưng chưa có job.
- Submission PROCESSING nhưng worker/job không còn active.
- Payment PENDING quá thời gian.
- Data deletion hoặc cleanup job chưa hoàn thành.

17.4 Retry

Hangfire không retry mà tất cả exception. Grading service phân loại:

Lỗi	Retry	Xử lý
Timeout, network, 429, 5xx	Có	Backoff và giới hạn attempt
Structured output sai	Có giới hạn	Corrective retry
400 do request sai	Không	Fail và cảnh báo cấu hình
401/403 do key/quyền	Không	Critical alert
Budget exceeded / grading disabled	Không	Giữ hoặc release credit theo policy

18. Vận hành OpenAI

18.1 Budget controls

Các setting bắt buộc:

- DailyAiBudgetLimit và monthly warning.
- MaxConcurrentAiJobs.
- MaxEssayWords và CreditCostPerGrading.
- AiGradingEnabled, FreeGradingEnabled.

Ngưỡng	Hành động đề xuất
70% budget	Warning và kiểm tra xu hướng
90% budget	High alert, xem xét giảm concurrency/tắt free grading
100% budget	Hard limit theo policy; ưu tiên bảo vệ paid user hoặc tạm dừng grading

18.2 Provider incident

Failure tăng → Circuit Breaker OPEN → Job reschedule/queue → Credit vẫn RESERVED → Thông báo user/admin → HALF-OPEN test → Phục hồi hoặc tiếp tục dừng

Nếu sự cố kéo dài, có thể tắt grading, release reservation phù hợp và đăng thông báo hệ thống.

18.3 Prompt deployment

Tạo Prompt Version → Benchmark → Test Staging → Activate → Theo dõi → Rollback Prompt nếu cần

Không ghi đè prompt production mà không có version và audit.

18.4 AI quality monitoring

Theo dõi JSON validity, điểm bất thường, feedback rỗng, output quá dài, error code lạ, quality dispute và re-grade rate.

19. Vận hành BandUp Credit

19.1 Ledger là nguồn dữ liệu chính

Không sửa trực tiếp balance. Mọi thay đổi phải tạo Credit Transaction:

PURCHASE - BONUS - RESERVE - CONSUME - RELEASE - REFUND - ADMIN_ADJUSTMENT - EXPIRATION

19.2 Credit reconciliation

Recurring job kiểm tra:

- Wallet balance bằng tổng ledger hợp lệ.
- Reservation quá hạn.
- Submission completed nhưng chưa consume.
- Submission failed nhưng chưa release.
- Payment paid nhưng chưa grant credit.
- Transaction hoặc grant bị trùng.

19.3 Admin adjustment

Admin cần permission, reason, reference và audit. Admin gọi Credit Service tạo transaction; không sửa cột balance bằng SQL hoặc form trực tiếp.

20. Vận hành payOS

20.1 Webhook processing

Webhook handler phải:

1. Xác minh signature/checksum.
2. Kiểm tra order, amount và trạng thái.
3. Kiểm tra idempotency.
4. Lưu webhook event.
5. Chuyển payment state.
6. Gọi Credit Service để grant đúng một lần.

Không cộng credit dựa trên return URL, frontend báo thành công hoặc screenshot.

20.2 Payment reconciliation

Job định kỳ kiểm tra order pending quá lâu, webhook chưa tới và payment paid nhưng credit chưa được cộng. Backend chủ động truy vấn lại provider khi cần.

20.3 Refund

MVP có thể tự động refund credit qua ledger; refund tiền ngân hàng do admin xử lý thủ công hoặc theo khả năng provider. Payment gốc không bị xóa và mọi refund phải có record/audit.

21. Support operations

21.1 Priority

Priority	Ví dụ	Mục tiêu nội bộ
P0	Sai tiền/credit diện rộng, mất dữ liệu	Xử lý ngay
P1	Payment chưa nhận credit, không chấm được diện rộng	Trong ngày
P2	Lỗi đơn lẻ, kết quả thiếu, vấn đề tài khoản	Trong 1 ngày làm việc
P3	Góp ý và yêu cầu tính năng	Theo backlog

21.2 Workflow

OPEN → IN_REVIEW → WAITING_FOR_USER → RESOLVED → CLOSED

Admin có thể reply, request information, re-grade, refund credit, assign hoặc close. Không chỉnh sửa assessment tùy ý.

22. Backup strategy

22.1 Database

Đề xuất ban đầu:

- Full backup hằng ngày.
- Rolling retention 30 ngày.
- Ít nhất một bản ngoài VPS chính.
- Mã hóa khi truyền/lưu nếu phù hợp.
- Theo dõi kích thước, duration và trạng thái backup.

Khi lượng user/transaction tăng, bổ sung backup nhiều lần/ngày hoặc WAL/point-in-time recovery.

22.2 Object storage

Nếu file nằm trên VPS: backup offsite, checksum và lifecycle. Nếu dùng object storage ngoài: private access, lifecycle và versioning khi phù hợp.

22.3 Configuration

Backup Docker Compose, reverse proxy config, migration history và tài liệu runbook. Secret backup phải được mã hóa và giới hạn quyền.

23. Restore và disaster recovery

23.1 Restore test

Tạo database test → Restore backup → Apply migration phù hợp → Khởi động app → Kiểm tra User/Submission/Payment/Credit → Ghi kết quả

23.2 Restore Production

1. Đánh giá incident và bật Maintenance Mode.
2. Dừng các luồng ghi dữ liệu mới.
3. Chọn backup/restore point phù hợp.
4. Restore database và storage liên quan.
5. Apply migration tương thích.
6. Chạy payment/credit reconciliation.
7. Chạy Deletion Ledger để không phục hồi user đã xóa.
8. Smoke test và xác minh dữ liệu.
9. Mở lại dịch vụ và theo dõi.
10. Viết incident report/postmortem.

23.3 RPO và RTO mục tiêu

Chỉ số	MVP	Hướng nâng cấp
RPO	Tối đa 24 giờ	Giảm bằng backup thường xuyên/PITR khi có nhiều user trả phí
RTO	Vài giờ	Tự động hóa restore và hạ tầng dự phòng

24. Data retention

Dữ liệu	Retention đề xuất	Ghi chú
---------	-------------------	---------

Essay, assessment, progress	Trong thời gian tài khoản tồn tại	Xóa khi account deletion
Draft bỏ dở	90 ngày	Cleanup theo batch
Raw AI response	Không lưu hoặc tối đa 7 ngày	Chỉ phục vụ debug có kiểm soát
Application log	30 ngày	Không chứa essay/secret
Error log	90 ngày	Phục vụ điều tra lỗi
Security event	12 tháng	Có thể kéo dài khi incident
Admin audit	24 tháng	Payment audit theo retention tài chính
Support ticket	12 tháng sau khi đóng	Attachment 90 ngày
Product analytics thô	13 tháng	Aggregate ẩn danh có thể giữ lâu hơn
Database backup	Rolling 30 ngày	Có bản offsite
Payment/accounting	Theo yêu cầu pháp luật áp dụng	Anonymize khi có thể

Cleanup job phải có log, metric, batch size và không khóa database quá lâu.

25. Xóa tài khoản

25.1 Workflow

User yêu cầu xóa → Re-authenticate Google → Cảnh báo → DataDeletionRequest → Revoke Sessions → Worker xóa/anonymize → Delete Objects → DeletionLedger → Completed

25.2 Dữ liệu xóa

Profile, Google external identifier, avatar, draft, essay, assessment, mistakes, progress, redo, notification, support attachment và analytics có thể định danh.

25.3 Dữ liệu giữ tối thiểu

Payment/refund/accounting record và audit liên quan tranh chấp hoặc nghĩa vụ pháp lý. Thông tin nhận dạng phải xóa/mask nếu không còn cần thiết.

25.4 Backup

Không sửa từng backup cũ. Backup tự hết hạn; khi restore backup cũ phải áp dụng lại Deletion Ledger.

26. Security operations

26.1 Access policy

Mỗi người dùng tài khoản riêng; không dùng chung admin account. Role/permission gồm Content Admin, User Support Admin, Finance Admin, Security Admin và Super Admin.

26.2 Review định kỳ

- Ai còn quyền admin/production?
- Tài khoản không hoạt động còn quyền không?
- Người rời nhóm đã revoke chưa?
- Permission có rộng hơn nhiệm vụ không?

26.3 Admin security

Khuyến nghị Google 2-Step Verification, session ngắn hơn, re-authentication cho hành động nguy hiểm, audit và có thể IP restriction cho Super Admin.

26.4 Patch management

Cập nhật OS, Docker, reverse proxy, .NET, Node, NuGet/npm packages, database, Hangfire và storage provider sau khi kiểm thử Staging.

27. Dependency và vulnerability management

CI nên kiểm tra dependency, container base image, secret leak và license khi cần.

Mức độ	Xử lý
Critical	Điều tra và patch khẩn cấp; ưu tiên auth/payment/database
High	Lên release gần nhất, có mitigation tạm thời
Medium	Theo dõi và cập nhật theo lịch
Low	Xử lý định kỳ

28. Capacity và performance

Theo dõi CPU, RAM, disk, I/O, network, container restart, database size và backup size.

Ngưỡng tham khảo	Hành động
Disk trên 70%	Warning và dự báo tăng trưởng
Disk trên 85%	High alert, cleanup/mở rộng ngay
RAM thường xuyên trên 80%	Kiểm tra process, query và worker concurrency
Queue latency tăng liên tục	Kiểm tra worker, provider, database và rate limit
Slow query tăng	Review index/query plan

Scale up trước: tăng CPU/RAM, tối ưu query/index và log. Scale out sau: tách Worker, managed database, external storage, Redis và load balancer.

29. Cost management

29.1 Nhóm chi phí

VPS, domain, backup/storage, OpenAI, email, payment fee và monitoring.

29.2 AI cost

Theo dõi chi phí/ngày, tháng, bài, user, prompt version, retry và failed call.

29.3 Profitability

Doanh thu gộp - Payment Fee - Refund - OpenAI Cost - Infrastructure Cost = Lợi nhuận ước tính

Budget alert có ba mức: Warning, Soft Limit và Hard Limit. Hard Limit có thể tắt free grading, giảm concurrency hoặc tạm dừng grading theo policy.

30. Maintenance Mode

Dùng khi migration lớn, restore, payment/credit incident, security incident hoặc thay đổi hạ tầng quan trọng.

Khi bật:

- Không nhận submit/payment mới nếu không an toàn.
- Có thể cho phép đọc dữ liệu nếu không ảnh hưởng.
- Admin Portal vẫn truy cập theo permission.
- Có thông báo rõ dịch vụ bị ảnh hưởng và trạng thái dữ liệu.
- Có audit log và người chịu trách nhiệm.

31. Incident management

31.1 Severity

Mức	Mô tả
SEV-1	Mất dịch vụ, mất dữ liệu, sai tiền/credit diện rộng hoặc secret compromise
SEV-2	Chức năng cốt lõi lỗi cho nhiều user, có ảnh hưởng đáng kể
SEV-3	Lỗi giới hạn, có workaround, ảnh hưởng một nhóm nhỏ
SEV-4	Lỗi nhỏ, thẩm mỹ hoặc góp ý

31.2 Quy trình

Detect → Acknowledge → Contain → Diagnose → Mitigate → Recover → Verify
→ Communicate → Postmortem

Dù chỉ có một người vận hành, incident record vẫn ghi owner, timeline, severity, user bị ảnh hưởng, dữ liệu/tài chính bị ảnh hưởng và thao tác xử lý.

32. Runbook catalog

Tối thiểu phải có runbook cho:

1. API down hoặc readiness fail.
2. Database không kết nối.
3. VPS hết disk.
4. Worker dừng hoặc Hangfire queue nghẽn.
5. OpenAI lỗi diện rộng hoặc cost tăng bất thường.
6. Payment webhook không tới hoặc credit không được cộng.
7. Credit cộng/trừ trùng hoặc ledger mismatch.
8. User mất draft hoặc Google Login lỗi.
9. Cookie mất hiệu lực sau deploy.
10. Backup thất bại hoặc cần restore Production.
11. Secret/payOS credential bị lộ.
12. Admin account bị chiếm quyền.
13. XSS, malicious attachment hoặc database intrusion.

Mỗi runbook gồm: triệu chứng, severity, kiểm tra đầu tiên, containment, bước xử lý, xác minh phục hồi, communication và follow-up.

33. Runbook mẫu: OpenAI lỗi diện rộng

33.1 Triệu chứng

AI failure rate, 429/5xx, queue và thời gian chờ tăng.

33.2 Xử lý

1. Kiểm tra log, provider status, API key và budget.
2. Giảm worker concurrency nếu rate limit.
3. Mở circuit breaker hoặc tắt free grading.
4. Giữ/reschedule job; không consume credit khi chưa có kết quả.
5. Đăng system announcement nếu user bị ảnh hưởng.

6. Theo dõi provider và mở lại theo chế độ half-open.

33.3 Xác minh

AI call thành công trở lại, queue giảm, không có reservation thất lạc và các submission bị kẹt được recovery.

34. Runbook mẫu: Payment không cộng credit

34.1 Kiểm tra

Payment Order, provider transaction, webhook event/signature, payment state, Credit Transaction và idempotency key.

34.2 Xử lý

1. Không sửa balance trực tiếp.
2. Xác minh payment với payOS.
3. Cập nhật payment state qua service phù hợp.
4. Gọi Credit Service tạo transaction PURCHASE đúng một lần.
5. Ghi audit và thông báo user.
6. Điều tra webhook/reconciliation để ngăn lặp lại.

35. Postmortem

SEV-1 và SEV-2 cần postmortem gồm:

- Tóm tắt và timeline.
- User, dữ liệu và tài chính bị ảnh hưởng.
- Root cause và yếu tố góp phần.
- Vì sao monitoring/alert không phát hiện sớm.
- Điều đã làm tốt, điều cần cải thiện.
- Action items, owner và deadline.

Postmortem nhằm cải thiện hệ thống, không đổ lỗi cá nhân.

36. Lịch bảo trì định kỳ

Chu kỳ	Công việc
Hằng ngày	Alert, failed jobs, AI cost, payment errors, backup status, disk usage
Hằng tuần	Support backlog, payment failure, queue latency, error log, dependency high severity, credit reconciliation

Hằng tháng	Restore test, admin access review, cost review, security event, retention job, database growth, AI quality
Hằng quý	Secret rotation theo policy, disaster recovery exercise, permission review, incident action items, capacity planning

37. Production access policy

- SSH key; hạn chế password login và root login trực tiếp.
- Firewall chỉ mở port cần thiết.
- Database không public Internet.
- Hangfire Dashboard và internal metrics không public.
- Backup/storage private.
- Có danh sách người có production access và ngày review gần nhất.

Admin nghiệp vụ không mặc nhiên có quyền SSH/database. Quyền Admin Portal và quyền hạ tầng là hai phạm vi khác nhau.

38. Go-Live Checklist

38.1 Infrastructure

- ☐ Domain, DNS và HTTPS hoạt động.
- ☐ Firewall, Docker Compose và persistent volume đã cấu hình.
- ☐ Health check, monitoring và alerting hoạt động.
- ☐ Database và storage không public không cần thiết.

38.2 Security

- ☐ Production secrets riêng và không nằm trong source.
- ☐ Cookie Secure/HttpOnly/SameSite và CSRF/CSP đã kiểm tra.
- ☐ Authorization, admin roles, rate limit và audit hoạt động.
- ☐ payOS signature verification và OpenAI key protection đã test.

38.3 Data

- ☐ Migration/seed đúng và không có dữ liệu test.
- ☐ Backup offsite thành công và restore đã test.
- ☐ Retention và account deletion workflow hoạt động.

38.4 Product và Operations

- ☐ Google Login, Writing Room, Autosave, Submission và Result hoạt động.
- ☐ Credit, payment, support và Admin Portal hoạt động.

- ☐ Runbook, rollback, maintenance mode, kill switch và budget cap sẵn sàng.
- ☐ Có email hỗ trợ và người chịu trách nhiệm incident.

39. Operations Acceptance Criteria

Hệ thống chỉ đủ điều kiện Production khi:

- Có Development, Staging và Production tách biệt hợp lý.
- Production dùng HTTPS và secret management.
- CI tự động build/test, có deploy và rollback procedure.
- Migration đã test trên Staging.
- Có health check, structured logging, metrics và alerting.
- Backup nằm ngoài VPS và restore đã được thử.
- Hangfire Dashboard được bảo vệ; worker restart không mất job.
- AI failure không làm mất credit.
- Webhook trùng không cộng credit trùng.
- Payment và Credit reconciliation hoạt động.
- Retention và account deletion jobs hoạt động.
- Có incident severity, runbook, postmortem và go-live checklist.
- Có owner cho support, payment và incident.

40. Phụ lục A - Environment Variables Checklist

Nhóm	Secret	Ví dụ cấu hình
Database	Có	Connection string, command timeout
Google Auth	Có	Client ID, Client Secret, callback path
OpenAI	Có	API key, model, timeout, budget
payOS	Có	Client ID/API key/checksum key, return/cancel URL
Cookie/Data Protection	Có một phần	Cookie name, expiry, key ring path
Hangfire	Không/connection secret	Queue, concurrency, storage connection
Storage	Có khi external	Provider, bucket, endpoint, access key
Email	Có	SMTP/provider credentials, sender address

Retention	Không	Số ngày cho log, draft, attachment, backup
Monitoring	Có thể có	DSN/token và alert channel

41. Phụ lục B - Service Dependency Matrix

Service	Database	External	Khi dependency lỗi
Web	Không trực tiếp	API	Hiển thị lỗi/kết nối lại
API	Bắt buộc	Google, payOS tùy endpoint	Readiness fail nếu DB; degrade theo chức năng ngoài
Worker grading	Bắt buộc	OpenAI	Retry/circuit breaker, giữ credit reserved
Worker payment	Bắt buộc	payOS	Reconciliation retry, không grant mù
Worker maintenance	Bắt buộc	Storage tùy job	Retry và alert nếu cleanup/deletion fail

42. Phụ lục C - Release Checklist

1. Chốt release notes, version và migration list.
2. CI pass và artifact/image đã ký/tag đúng version.
3. Backup Production thành công.
4. Maintenance/deploy window được xác định nếu cần.
5. Apply migration và deploy theo runbook.
6. Health check và smoke test.
7. Kiểm tra login, draft, submit, worker, result, payment và credit.
8. Theo dõi metrics tối thiểu 15-30 phút hoặc theo risk.
9. Ghi kết quả release và issue phát sinh.

43. Phụ lục D - Monthly Maintenance Checklist

- ☐ Restore một backup vào môi trường test.
- ☐ Review admin/production access.
- ☐ Review AI cost, payment fee và profitability.
- ☐ Review failed jobs, retry và queue latency.
- ☐ Review security event và dependency vulnerabilities.
- ☐ Review database/disk growth và backup size.

- ☐ Review retention cleanup và Deletion Requests.
- ☐ Review support SLA nội bộ và quality disputes.
- ☐ Cập nhật runbook/postmortem action items.

44. Kết luận

BandUp được vận hành theo nguyên tắc: dữ liệu và tiền phải đúng trước, trải nghiệm phải phục hồi được, chi phí AI phải được kiểm soát và mọi thao tác nhạy cảm phải có khả năng truy vết.

Phương án baseline: VPS + Docker Compose + reverse proxy; ba môi trường; CI/CD có version và approval; Hangfire Worker riêng; OpenAI budget/circuit breaker; payOS webhook + reconciliation; credit ledger + reconciliation; structured logging; backup offsite hằng ngày; restore test định kỳ; retention tự động; incident runbook và post-mortem.